SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no	192465054	**Name of the Student**	A Abhinava Reddy

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I A Abhinava Reddy,192465054(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

A Abhinava Reddy

CSA6303 – Threat Intelligence and Network Security

Answers to Questions 1 – 6

Q1. Common Types of Network Attacks [10 Marks]

A network attack is an attempt to gain unauthorised access to a network, disrupt its services, or steal or damage data. The four common types are summarised below.

1. Malware

Malware (malicious software) is code designed to damage, spy on or take control of a system without the owner's consent. Main types:

Type	Description	Example
Virus	Attaches to a host file or program and spreads when the infected file is executed or shared.	ILOVEYOU virus
Worm	Self-replicates across networks by exploiting vulnerabilities, with no user action.	WannaCry (spread worm-like via SMB), Conficker
Trojan	Disguised as legitimate software; opens backdoors or drops other malware.	Zeus banking trojan
Ransomware	Encrypts the victim's files and demands payment for the decryption key.	WannaCry, Ryuk
Spyware	Secretly records keystrokes, browsing and personal data and sends them to the attacker.	Keyloggers, Pegasus

Preventive measure: install and regularly update antivirus/anti-malware and OS patches, and avoid untrusted downloads and attachments.

2. Phishing

Phishing is a social-engineering attack in which deceptive emails, messages, links or fake websites trick users into revealing credentials, card details or installing malware. The attacker impersonates a trusted entity (bank, employer, courier) and creates urgency.

Example: a fake "bank account suspended" email with a link to a cloned login page that captures the username and password.

Preventive measure: user awareness training, email filtering (SPF/DKIM/DMARC), verifying URLs before clicking, and multi-factor authentication.

3. DoS (Denial of Service)

A DoS attack floods a target server or network with traffic or requests from a single source so that legitimate users cannot access the service.

Example: SYN flood or ping flood launched from one machine.

Preventive measure: rate limiting, firewall/IPS rules to block the offending source, and tuning connection timeouts.

4. DDoS (Distributed Denial of Service)

A DDoS attack uses a botnet, a large network of compromised devices, to send massive traffic from many sources at once. It is harder to block because there is no single attacker IP.

Example: Mirai botnet attack on Dyn DNS (2016), using hijacked IoT devices.

Preventive measure: CDN and traffic scrubbing services, load balancing, anycast distribution and upstream ISP filtering.

Summary

Attack	Example	Preventive measure
Malware	Ransomware (WannaCry)	Antivirus and patching
Phishing	Fake bank login email	Awareness training, MFA
DoS	SYN flood from one host	Rate limiting, firewall
DDoS	Mirai botnet flood	CDN, traffic scrubbing

Q2. Man-in-the-Middle (MitM) Attack [8 Marks]

Definition: A Man-in-the-Middle attack occurs when an attacker secretly intercepts, and possibly alters, the communication between two parties who believe they are communicating directly with each other.

How it works

1. Interception: the attacker positions themselves in the communication path (on the LAN, a Wi-Fi network or the routing path).
2. Relaying: the attacker captures traffic from the victim and forwards it to the real destination, so the session appears normal.
3. Exploitation: the attacker reads data (passwords, card numbers, messages), modifies content or injects malicious data, then relays responses back to the victim.

Techniques used

- **ARP poisoning:** forged ARP replies map the attacker's MAC to the gateway's IP, so LAN traffic passes through the attacker.
- **Rogue Wi-Fi access point (evil twin):** a fake hotspot with a familiar name lures users to connect; all traffic flows through the attacker.
- **DNS spoofing:** false DNS responses redirect the victim to a malicious site that looks genuine.
- **Session hijacking:** the attacker steals a session ID or cookie to take over an authenticated session.
- **SSL stripping:** downgrades HTTPS to HTTP so data travels in plaintext.

Countermeasures

- **HTTPS/TLS:** encrypts data in transit so intercepted traffic is unreadable.
- **VPN:** creates an encrypted tunnel, protecting traffic on untrusted networks.
- **Certificate validation:** browsers verify server certificates, exposing fake sites.
- **HSTS:** forces browsers to use HTTPS only, preventing SSL stripping.
- **Dynamic ARP Inspection (DAI):** switches validate ARP packets against trusted bindings (DHCP snooping), blocking ARP poisoning.

- **Other:** avoid public Wi-Fi, use MFA, and use secure DNS (DNSSEC).

Q3. Spoofing vs Sniffing [8 Marks]

Aspect	Spoofing	Sniffing
Definition	Forging identity (IP, MAC, email, DNS) to impersonate a trusted source.	Passively capturing and analysing packets travelling on a network.
Nature	Active; sends forged data.	Passive; only listens, so hard to detect.
Purpose	Bypass authentication, redirect traffic, hide identity.	Eavesdrop on data and credentials.
Affects	Authentication and integrity.	Confidentiality.
Tools	Scapy, arpspoof, hping.	Wireshark, tcpdump.

Types of spoofing

- **IP spoofing:** forged source IP in packet headers; used in DDoS and to bypass IP-based filters.
- **MAC spoofing:** changing the MAC address to impersonate another device or bypass MAC filtering.
- **ARP spoofing:** fake ARP replies to redirect LAN traffic through the attacker.
- **Email spoofing:** forged sender address in emails, commonly used in phishing.
- **DNS spoofing:** false DNS records redirect users to malicious sites.

Sniffing: detection and prevention

Detection:

- Check for NICs in promiscuous mode (e.g. with tools such as Nmap scripts or sniffer-detection utilities).
- Use IDS/IPS and monitor for ARP anomalies, unusual MAC changes and duplicate IPs (e.g. arpwatch).
- Look for abnormal latency or unexpected rogue devices on the network.

Prevention:

- Encrypt traffic (HTTPS, SSH, TLS, VPN) so captured packets are unreadable.
- Use switched networks instead of hubs, as switches send frames only to the destination port.
- Enable port security and Dynamic ARP Inspection, and apply anti-spoofing filters (ingress/egress filtering, DHCP snooping).
- Use network segmentation and strong Wi-Fi encryption (WPA2/WPA3).

Q4. Vulnerability Assessment [8 Marks]

Definition: Vulnerability assessment is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications so that they can be fixed before attackers exploit them.

Steps in the process

1. Asset identification: list the hosts, devices, applications and data in scope and note their criticality.

2. Scanning: run automated tools such as Nessus or OpenVAS to detect open ports, missing patches, misconfigurations and known flaws.
3. Analysis: validate results, remove false positives and identify root causes.
4. Risk rating: score each finding (e.g. CVSS) considering likelihood and business impact.
5. Reporting: document the findings and recommend fixes; then remediate and re-scan.

Contents of a good vulnerability assessment report

- **Executive summary:** a non-technical overview of the overall risk posture and key findings.
- **Scope and methodology:** systems assessed, tools used, dates and approach.
- **Findings with CVE IDs:** each vulnerability identified using its CVE identifier and description.
- **CVSS severity scores:** Low / Medium / High / Critical ratings for each finding.
- **Evidence:** screenshots, scan output and affected hosts or ports.
- **Risk impact:** the potential effect on confidentiality, integrity, availability and the business.
- **Prioritised remediation recommendations:** specific patches or mitigations, ordered by risk, with owners and timelines.

Vulnerability assessment vs penetration testing

Aspect	Vulnerability assessment	Penetration testing
Goal	Identify and list weaknesses.	Exploit weaknesses to prove real impact.
Method	Mostly automated scanning.	Manual, simulating a real attacker.
Depth	Broad coverage, no exploitation.	Deep, exploits and chains vulnerabilities.
Frequency	Regular and ongoing.	Periodic (e.g. annually).

Q5. Open-Source Intelligence (OSINT) and Threat Data [8 Marks]

OSINT: Open-Source Intelligence is intelligence derived from publicly available information that is collected, analysed and used to support decision making, such as profiling threat actors, discovering exposed assets and tracking new threats.

Common threat data sources

Category	Examples	Use
OSINT / public	WHOIS, Shodan, social media, news, forums, code repositories (GitHub), CVE/NVD databases.	Domain ownership, exposed devices, leaked credentials, vulnerability details.
Internal	Firewall, IDS and server logs, honeypots, past incident records.	Environment-specific, highly relevant threat data.
Commercial	Paid intelligence providers and curated feeds.	Enriched, validated intelligence with support.
Community / external	CERTs, ISACs, vendor advisories.	Shared threat information.

Techniques used to collect threat data

- **Passive collection:** gathering information without interacting with the target (reading public records, search engines, archives).

- **Web scraping:** automated extraction of data from websites, forums and paste sites.
- **DNS and domain lookups:** WHOIS, reverse DNS and passive DNS to map infrastructure and related domains.
- **Search-engine techniques:** Google dorking and Shodan queries to find exposed systems.
- **Honeypots and log collection:** capturing attacker behaviour and internal telemetry.

Legal and ethical considerations

- Only use publicly available data and respect terms of service and applicable laws (e.g. IT Act, GDPR/privacy laws).
- Avoid unauthorised access or active probing of systems without permission.
- Protect personal data and privacy, and use the information only for legitimate security purposes.
- Verify the reliability of sources, as public information may be inaccurate or deliberately misleading.

Q6. Indicators of Compromise (IoCs) and Threat Feeds [8 Marks]

Definition: Indicators of Compromise are pieces of forensic evidence or artefacts that suggest a system or network has been breached or is under attack.

Types of IoCs

Type	Description	Examples
File-based	Properties of malicious files.	File hashes (MD5/SHA-256), suspicious file names or paths.
Network-based	Seen in network traffic.	Malicious IP addresses, domains, URLs; unusual or beaconing traffic.
Host-based	Changes on an endpoint.	Registry keys, new processes or services, unauthorised accounts.

How threat feeds improve defence

A threat feed is a continuously updated stream of threat data (IoCs) provided by open-source or commercial sources, often in formats such as STIX/TAXII.

- Delivered to SIEM, IDS/IPS and firewalls for automatic alerting and blocking of known malicious IPs, domains and hashes.
- Enable faster detection and response, since new threats are identified quickly.
- Provide wider visibility than internal logs alone and reduce the effort of collecting intelligence.
- STIX standardises how threat information is described and TAXII transports it, allowing automated sharing between organisations.

Limitations

- **False positives:** legitimate IPs or files may be flagged, leading to alert fatigue or blocked services.
- **Stale data:** IoCs such as IP addresses become outdated quickly if not aged out.
- **Need for context:** raw indicators without context are hard to prioritise and may not be relevant to the organisation.